

MBA EM **ENGENHARIA DE SOFTWARE**

Legislação no Ambiente Digital (LGPD) II

Prof^a. Ana Carla Bliacheriene

A responsabilidade pela idoneidade, originalidade e licitude dos conteúdos didáticos apresentados é do professor.

Proibida a reprodução, total ou parcial, sem autorização.

Lei nº 9610/98

Imersão em Privacidade e Código

Formato da Aula

Esta aula combina teoria essencial com aplicação prática. Cada capítulo termina com uma atividade interativa para fixar o conteúdo.

O que você vai levar para casa

- Compreensão sólida da LGPD do ponto de vista técnico
- Ferramentas e padrões aplicáveis ao seu dia a dia de dev
- Confiança para liderar decisões de privacidade na sua equipe



Por que a LGPD é Crucial para Você?

O Problema

Empresas já foram autuadas e multadas pela ANPD por não conformidade. Incidentes de vazamento de dados geram não apenas multas milionárias, mas danos irreparáveis à reputação e perda de confiança dos usuários.

A Solução

Desenvolver software com privacidade desde o início — o chamado **Privacy by Design** — é mais barato, mais eficiente e mais ético do que corrigir problemas depois que eles ocorrem.

Seu Papel

O engenheiro de software é o **guardião dos dados** no ciclo de desenvolvimento. Você decide como os dados são coletados, armazenados, processados e descartados. Esse poder vem com responsabilidade.

O Que Vamos Cobrir Hoje



Fundamentos da LGPD

O que você PRECISA saber sobre a lei e seu contexto



Princípios da LGPD

Os 10 pilares da construção segura e responsável



Direitos dos Titulares

O que o usuário pode exigir e como implementar



Dados Pessoais e Sensíveis

Identificando e classificando o alvo da proteção



Bases Legais

Quando e como tratar dados com respaldo legal



Segurança e Boas Práticas

Da arquitetura ao deploy com privacidade integrada



CAPÍTULO 1

A Base da Proteção de Dados

Antes de escrever uma linha de código que trata dados pessoais, você precisa entender o arcabouço legal que governa essa responsabilidade. Vamos começar pelos fundamentos.

O Que é a LGPD?

A Lei em Resumo

A **Lei Geral de Proteção de Dados Pessoais (Lei nº 13.709/2018)** entrou em vigor em setembro de 2020 e representa o marco regulatório brasileiro para o tratamento de dados pessoais. Ela é válida para qualquer operação realizada em território nacional — tanto em meios **físicos quanto digitais**.

Inspiração Internacional

A LGPD foi amplamente inspirada na **GDPR europeia** (General Data Protection Regulation), adotando conceitos similares como consentimento, finalidade e direitos dos titulares, adaptando-os ao contexto brasileiro.

Objetivo Central

Proteger os **direitos fundamentais de liberdade e privacidade** das pessoas naturais, garantindo que seus dados pessoais sejam tratados de forma transparente, segura e ética por organizações públicas e privadas.

Abrangência

- Dados coletados no Brasil ou de brasileiros
- Dados físicos e digitais
- Empresas nacionais e estrangeiras
- Setor público e privado

Quem é a ANPD?

O Que É

A **Autoridade Nacional de Proteção de Dados** é o órgão federal responsável por zelar pela proteção dos dados pessoais no Brasil, vinculada à Presidência da República.

Funções Principais

Fiscalizar o cumprimento da LGPD, regulamentar detalhes da lei, orientar controladores e operadores, e aplicar sanções administrativas em caso de infração.

Poder de Sanção

As multas podem chegar a **2% do faturamento** da empresa no Brasil, limitado a **R\$ 50 milhões por infração**. Além de multas, a ANPD pode publicizar a infração e suspender o tratamento de dados.

 **Atenção:** A ANPD já iniciou processos administrativos contra empresas brasileiras. A conformidade não é opcional — é uma exigência legal com consequências reais e imediatas.

Privacidade: Um Direito Fundamental

A privacidade não é apenas um requisito regulatório — é um **direito humano fundamental** reconhecido pela Constituição Federal brasileira (Art. 5º, X). Ao construir sistemas que tratam dados pessoais, engenheiros de software assumem a responsabilidade de proteger esse direito.

Constituição Federal

Art. 5º, X — inviolabilidade da intimidade, vida privada, honra e imagem

LGPD

Lei 13.709/2018 — regulamentação específica para tratamento de dados pessoais

ANPD

Fiscalização, orientação e sanção para garantir o cumprimento da lei





Atividade 1: Quiz Rápido — "Você é um Guardião de Dados?"



ATIVIDADE INTERATIVA 1

⌚ 15 minutos

Hora de testar o que você já sabe (e o que está aprendendo)! Responda individualmente e depois discutiremos as respostas.

1

Pergunta 1

"Qual é o valor máximo da multa por infração à LGPD?"

a) R\$ 10 mil | b) R\$ 5 milhões | c) R\$ 50 milhões | d) Ilimitado

2

Pergunta 2

"A LGPD se aplica apenas a dados digitais?"

a) Sim, apenas online | b) Não, também dados físicos | c) Somente a empresas de tecnologia

3

Pergunta 3

"Em que ano a LGPD entrou em vigor efetivamente?"

a) 2018 | b) 2019 | c) 2020 | d) 2021

4

Pergunta 4

"Qual regulamentação europeia inspirou a LGPD?"

a) CCPA | b) GDPR | c) PDPA | d) HIPAA



CAPÍTULO 2

Identificando o Alvo — Dados Pessoais

Antes de proteger, é preciso identificar. Nem todo dado é "dado pessoal" nos termos da LGPD — mas a definição é mais ampla do que a maioria dos engenheiros imagina.

Dados Pessoais: Qualquer Informação que Identifica

De acordo com a LGPD, dado pessoal é "**qualquer informação relacionada a pessoa natural identificada ou identificável**". A chave está na possibilidade de identificação — direta ou indireta.

Identificação Direta

- Nome completo
- CPF / RG / CNH
- E-mail pessoal
- Número de telefone
- Endereço residencial

Identificação Indireta

- Endereço IP (isolado ou combinado)
- Dados de geolocalização
- Cookies e identificadores de sessão
- Histórico de navegação
- Device fingerprint



💡 IP + Histórico de navegação juntos podem identificar uma pessoa com alta precisão. Contexto importa!

Dados Pessoais Sensíveis: Proteção Redobrada

Alguns dados, por sua natureza, podem gerar discriminação ou causar danos graves aos titulares. A LGPD classifica estes como **dados sensíveis** e exige tratamento ainda mais criterioso, com bases legais específicas.



Biométricos e Genéticos

Impressões digitais, reconhecimento facial, exames de DNA. Ex: sistemas de ponto eletrônico com biometria.



Saúde e Vida Sexual

Prontuários, diagnósticos, medicações. Sistemas de saúde digital devem ter cuidado especial com esses dados.



Crença e Opinião

Convicção religiosa, opinião política, filiação a sindicatos ou organizações de caráter religioso, filosófico ou político.



Origem Racial ou Étnica

Dados que revelem ou permitam inferir a origem étnica ou racial de um indivíduo são protegidos com rigor máximo.

Todo Dado Conta uma História

O Risco da Combinação de Dados

Individualmente, um dado pode parecer inofensivo. Mas a combinação de múltiplos dados — o chamado **efeito mosaico** — pode revelar informações altamente sensíveis sobre uma pessoa sem que nenhum dado individualmente fosse classificado como sensível.

Exemplo Prático para Devs

Um app que combina: **horário de uso** + **localização** + **lista de contatos** pode inferir religião, orientação política ou relacionamentos pessoais. Como engenheiro, avalie sempre o impacto da combinação dos dados que você coleta.



Os Pilares da Construção Segura — Princípios da LGPD

A LGPD não diz apenas "proteja os dados". Ela estabelece **10 princípios fundamentais** que devem orientar cada decisão técnica e de negócio envolvendo dados pessoais.



Os 10 Princípios Fundamentais da LGPD

1

Finalidade

Propósito legítimo, específico e informado ao titular

2

Adequação

Compatível com as finalidades declaradas

3

Necessidade

Mínimo de dados para atingir a finalidade

4

Livre Acesso

Consulta facilitada aos dados pelo titular

5

Qualidade dos Dados

Exatidão, clareza, relevância e atualização

6

Transparência

Informações claras sobre o tratamento realizado

7

Segurança

Medidas técnicas e administrativas de proteção

8

Prevenção

Evitar danos antes que ocorram

9

Não Discriminação

Dados não podem ser usados para fins discriminatórios

10

Responsabilização

Demonstrar a conformidade com a lei

Foco para Engenheiros: Necessidade, Segurança e Transparência

Dos 10 princípios, três têm impacto direto e imediato nas decisões técnicas do dia a dia de desenvolvimento. Internalize estas perguntas no seu processo:



Necessidade (Data Minimization)

"Precisamos mesmo desse campo no banco de dados?" Colete apenas o que é estritamente necessário para a funcionalidade. Cada campo a mais é um risco a mais.



Segurança (Security by Design)

Criptografia em trânsito (TLS) e em repouso (AES-256), controle de acesso granular (RBAC), logs de auditoria, e gestão segura de secrets são obrigações, não opcionais.



Transparência (Privacy Notice)

O usuário precisa saber: quais dados são coletados, para que servem, com quem são compartilhados e por quanto tempo ficam armazenados. Implemente isso na interface.



Atividade 2: Cenário Prático — "O Que Fazer com Esse Dado?"

ATIVIDADE INTERATIVA 2

🕒 20 minutos

Cenário: Um aplicativo de delivery precisa implementar as seguintes funcionalidades. identifique: quais dados são necessários, quais são sensíveis, e qual princípio está sendo mais desafiado.



Caso A: Rastreamento em Tempo Real

"O app precisa da sua localização GPS em tempo real durante toda a jornada de entrega." Qual princípio está em jogo? (Finalidade? Necessidade?)



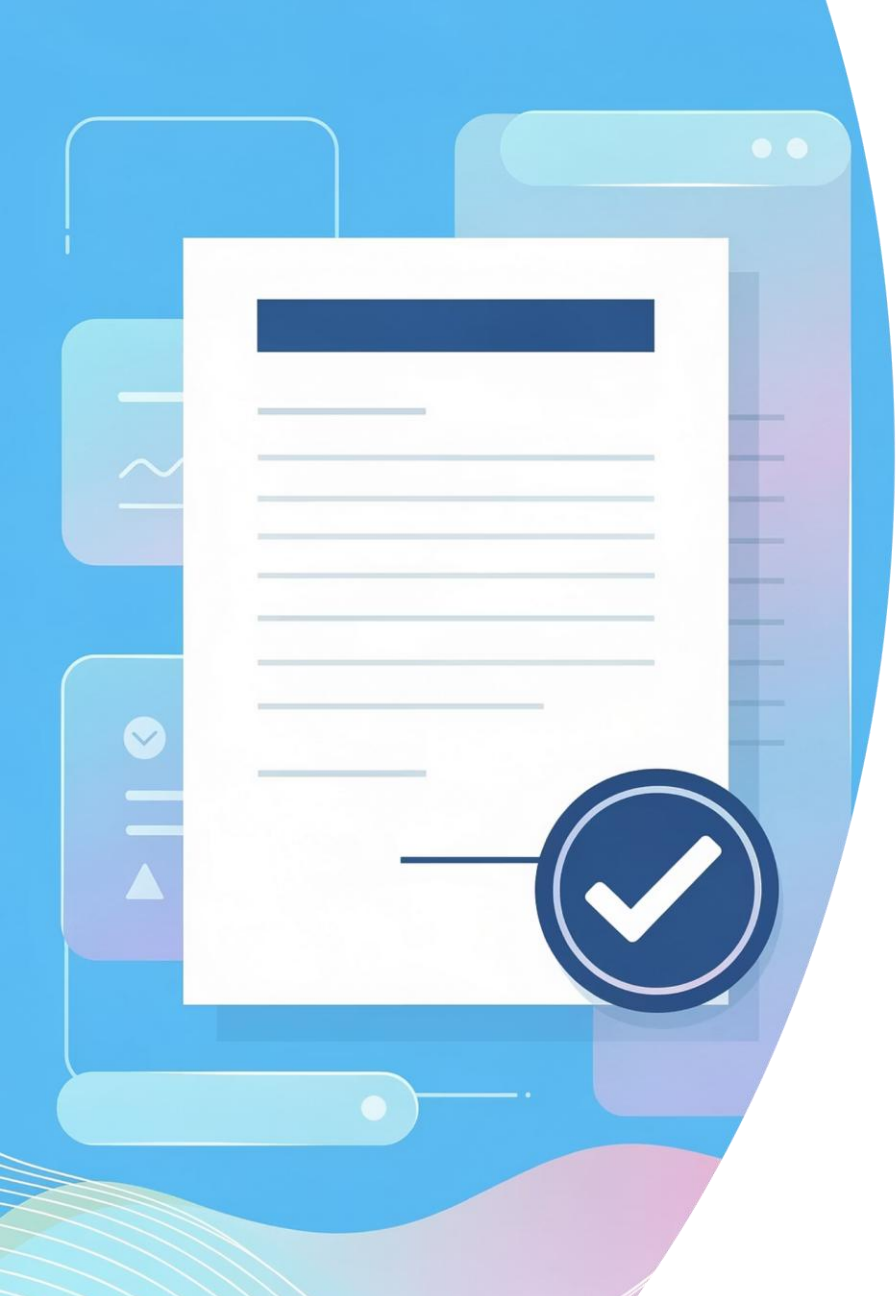
Caso B: Histórico de Pagamentos

"O app armazena todos os dados do cartão de crédito para facilitar compras futuras, sem perguntar ao usuário." Quais dados são sensíveis aqui?



Caso C: Perfil Comportamental

"O app analisa os pedidos para inferir preferências alimentares relacionadas a restrições religiosas ou de saúde." Que tipo de dado isso pode gerar?

A stylized illustration on the left side of the slide. It features a white document with horizontal lines representing text. A large blue circle with a white checkmark is positioned at the bottom right of the document. The background is a vibrant blue with abstract shapes and a purple-to-blue gradient at the bottom.

CAPÍTULO 4

A Permissão para Tratar — Bases Legais

Na LGPD, **não basta querer tratar dados**. É necessário ter uma base legal que justifique cada operação de tratamento. Usar a base errada pode invalidar todo o processamento.

Quando Podemos Tratar Dados Pessoais?

A LGPD prevê **10 hipóteses (bases legais)** que autorizam o tratamento de dados pessoais. Cada operação deve ser associada a pelo menos uma delas:

Consentimento

Autorização expressa, livre e informada do titular para finalidades específicas

Obrigação Legal

Cumprimento de obrigação legal ou regulatória. Ex: dados para a Receita Federal

Execução de Contrato

Dados necessários para executar um contrato com o titular. Ex: endereço para entrega

Interesse Legítimo

Equilíbrio entre o interesse legítimo do controlador e os direitos do titular

Tutela da Saúde

Para procedimentos realizados por profissionais da saúde ou autoridades sanitárias

Proteção da Vida

Situações de emergência onde é necessário proteger a vida do titular ou de terceiros

O Papel do Consentimento no Desenvolvimento

O Que é um Consentimento Válido?

- **Livre:** Sem pressão ou condicionamentos
- **Informado:** O titular sabe para que serve
- **Inequívoco:** Ação afirmativa clara (não pré-marcado!)
- **Específico:** Uma finalidade por vez
- **Revogável:** Fácil de retirar a qualquer momento

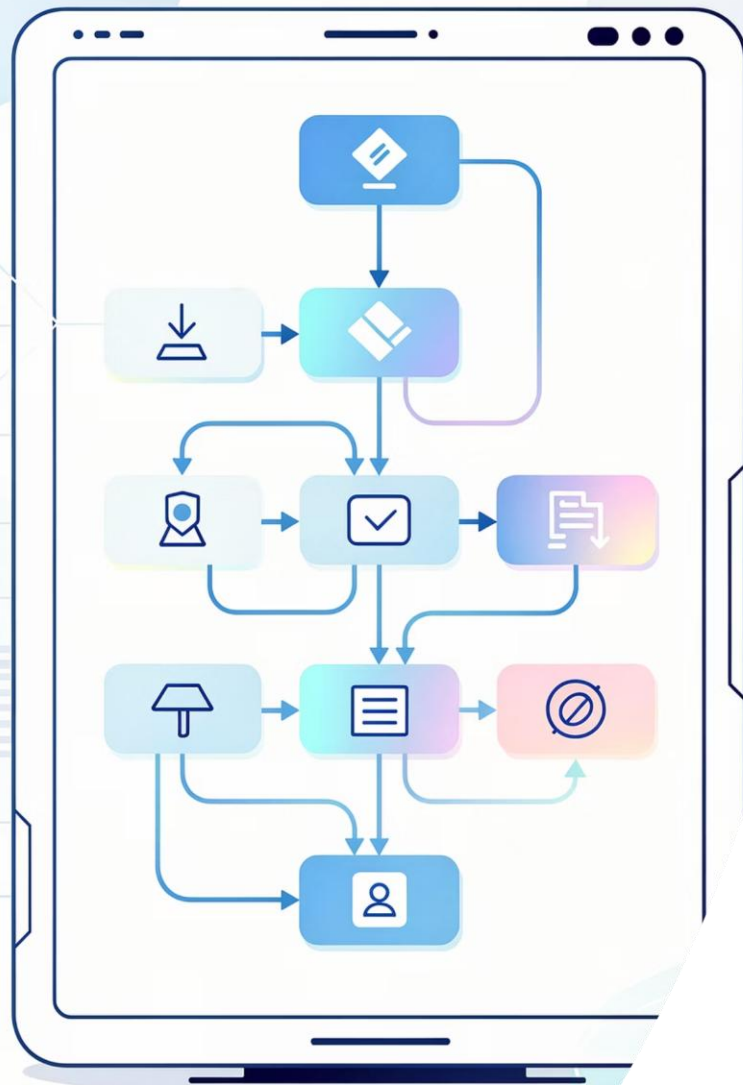
Como Implementar no Código?

O consentimento **não é um "aceite geral"** nos termos de uso. Como engenheiro, você precisa implementar:

- Fluxo de opt-in granular por finalidade
- Registro auditável de quando e como o consentimento foi dado
- Mecanismo simples para revogação (tão fácil quanto foi dar)
- Versionamento das políticas com rastreamento de aceite



⚠️ Checkbox pré-marcado = consentimento inválido na LGPD!



A Base Legal: A Permissão para Agir

Antes de implementar qualquer funcionalidade que trate dados, seu time deve responder: **"Qual é a nossa base legal para isso?"** Essa pergunta deve constar em refinamentos, code reviews e documentação técnica.

1

1. Identificar

Que dados serão tratados e para qual finalidade específica?

2

2. Mapear

Qual das 10 bases legais justifica esse tratamento?

3

3. Documentar

Registrar a base legal no mapeamento de dados (ROPA)

4

4. Implementar

Garantir que o código reflete a base legal escolhida



CAPÍTULO 5

O Poder do Titular — Direitos e Deveres

A LGPD coloca o titular dos dados no centro. O Art. 18 garante um conjunto de direitos que **todo sistema que trata dados pessoais deve ser capaz de atender**. Como engenheiro, você precisa construir esses mecanismos.

Direitos dos Titulares — Art. 18 da LGPD

Confirmação e Acesso

Confirmar a existência de tratamento e acessar os dados que foram coletados sobre si

Correção

Solicitar a correção de dados incompletos, inexatos ou desatualizados

Eliminação e Anonimização

Exigir a remoção ou anonimização de dados desnecessários, excessivos ou tratados sem base legal

Portabilidade

Receber seus dados em formato estruturado e interoperável para migrar para outro serviço

Revogação e Informação

Revogar o consentimento e ser informado sobre o compartilhamento de dados com terceiros

Como Implementar Esses Direitos no Código?



Acesso e Correção

Crie endpoints autenticados para que o usuário consulte e edite seus dados. Implemente validação de identidade antes de qualquer operação sensível. Registre todas as alterações em log de auditoria.



Portabilidade

Ofereça exportação em formatos abertos e interoperáveis (JSON, CSV, XML). O usuário deve poder baixar todos os seus dados de forma estruturada e legível por máquinas.



Eliminação e Anonimização

Implemente fluxo de exclusão que propague para todos os sistemas (bancos de dados, caches, backups, third-parties). Documente quais dados não podem ser eliminados e por qual base legal.



Revogação de Consentimento

A revogação deve ser tão simples quanto o consentimento. Um toggle nas configurações é o mínimo. Ao revogar, o sistema deve parar o tratamento baseado naquele consentimento imediatamente.



Atividade 3: Role-Playing — "O Usuário Exige Seus Direitos"

ATIVIDADE INTERATIVA 3

🕒 25 minutos

Cenário: Um usuário do seu sistema envia um e-mail solicitando a eliminação completa de todos os seus dados. Você é o engenheiro responsável. Em grupos, discuta e mapeie o processo técnico completo:

Verificar Identidade

Como autenticar que a solicitação é legítima sem expor dados?

1

2

Mapear os Dados

Em quais tabelas, serviços e sistemas externos esse usuário existe?

Verificar Restrições

Existem dados que não podem ser removidos por lei (ex: fiscal, contábil)?

3

4

Executar e Validar

Qual API ou script vai remover os dados? Como verificar que está completo?

Confirmar e Registrar

Como notificar o usuário e registrar a execução para fins de auditoria?

5

Construindo com Segurança e Privacidade

A segurança da informação não é apenas uma boa prática — a LGPD a torna uma **obrigação legal**. O Art. 46 exige medidas técnicas e administrativas aptas a proteger os dados pessoais de acessos não autorizados e situações acidentais ou ilícitas.



Segurança da Informação: Um Dever Legal e Ético

Medidas Técnicas

- **Criptografia em trânsito:** TLS 1.2+ obrigatório
- **Criptografia em repouso:** AES-256 para dados sensíveis
- **Controle de acesso:** RBAC com princípio do menor privilégio
- **Mascaramento de dados:** Em logs, staging e dev
- **WAF e Firewalls:** Proteção contra ataques externos
- **Tokenização:** Substituição de dados sensíveis por tokens

Medidas Administrativas

- Políticas de segurança da informação documentadas
- Treinamento regular da equipe
- Gestão de incidentes com plano de resposta
- Comunicação à ANPD em caso de vazamento em 72h

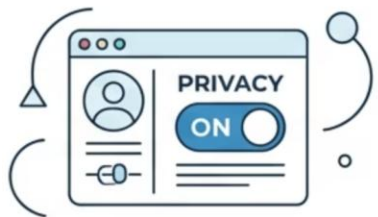
DPIA / RIPD

O **Relatório de Impacto à Proteção de Dados (RIPD)** deve ser realizado antes de implementar novas funcionalidades que envolvam alto risco ao titular. É obrigatório por lei.

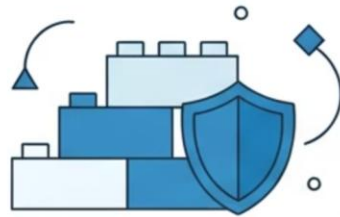
Privacy by Design: Os 7 Princípios na Prática



**1) PROATIVO
NÃO REATIVO**
- Prevenir antes
de remediar.



**2) PRIVACIDADE
COMO PADRÃO -**
Configurações de
maior privacidade
por padrão.



**3) PRIVACIDADE
INCORPORADA -**
Não como add-on,
parte da arquitetura.



**4) FUNCIONALIDADE
TOTAL -** Privacidade
+ usabilidade, sem
sacrifício.



**5) SEGURANÇA
PONTA A PONTA**
- Proteção durante
todo o ciclo de vida.



**6) VISIBILIDADE E
TRANSPARÊNCIA**
- Processos abertos
e verificáveis.



**7) RESPEITO
PELO USUÁRIO**
- Centralidade do
titular em decisões.



**7 PRINCÍPIOS
ESSENCIAIS**
PARA ENGENHEIROS
DE SOFTWARE.

O Privacy by Design não é uma metodologia separada — é uma **mentalidade que deve permear cada decisão de arquitetura, desenvolvimento e deploy**.
Incorpore esses princípios nos seus critérios de Definition of Done.

LGPD na Prática: Ferramentas e Automação

LGPD Sentinel AI

Ferramenta open-source que utiliza IA local (**FastAPI + LangChain + Ollama**) para automatizar tarefas de conformidade. Zero dados saem do servidor — ideal para atender ao Art. 46 da LGPD com custo zero.

- Mapeamento automático de fluxos de dados
- Geração de relatórios DPIA/RIPD
- Análise de código para identificar riscos de privacidade
- Custo: \$0.00 (auto-hospedado)

Outras Ferramentas Essenciais

- **OneTrust / Cookiebot:** Gestão de consentimento
- **Vault (HashiCorp):** Gestão segura de segredos
- **Presidio (Microsoft):** Detecção e anonimização de PII
- **Privacy.sexy:** Scripts para hardening de privacidade
- **OWASP Privacy Risks:** Checklist de riscos de privacidade

Conclusão: A Privacidade é um Feature, Não um Bug!

Você chegou ao fim de 3 horas de imersão em LGPD para engenheiros. A lei não é um obstáculo burocrático — é um **guia para construir software mais confiável, ético e sustentável**.

Revise seus Projetos

Audite os sistemas atuais: quais dados são coletados, com que base legal, e se os direitos dos titulares estão implementados.

Implemente Agora

Adicione criptografia onde falta, implemente o fluxo de consentimento correto e crie os endpoints de direitos dos titulares.

Lidere sua Equipe

Leve essa conversa para o próximo refinamento. Inclua LGPD nos critérios de aceite e no Definition of Done do seu time.

Continue Aprendendo

Explore a ANPD.gov.br, acompanhe as resoluções da ANPD e mantenha-se atualizado sobre precedentes e novas regulamentações.

  **Lembre-se:** Engenheiros de software são peças-chave na proteção dos dados de milhões de pessoas. Construa com responsabilidade, transparência e empatia pelo titular dos dados.

Obrigada!

Prof^a. Ana Carla Bliacheriene

MBA **USP**
ESALQ